🛡️ Weekly IT Security Brief (Official-source-first) | 2026-10-11 06:00

Formatted for readability · Auto-generated

📌 Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2015-5477(2026-10-11), CVE-2016-3081(2026-10-11), CVE-2023-22894(2026-10-11). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Post-quantum authentication: Why organizations should start testing certificate ecosystems now. Prepare for post-quantum authentication by testing certificate ecosystems now. Learn how Microsoft’s PQC TLS Pilot Program helps advance future re...
- Threat trend #2: 3 lessons from frontier AI vulnerability research. Read how How Microsoft Security's FORGE Lab is scaling vulnerability research from Windows to the Linux kernel. The post 3 lessons from frontier AI vulnerability research appeared first on Mi...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

🔎 Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2015-5477

CVE Title	CVE-2015-5477 | juniper/junos | Unknown Type
CVE Description	named in ISC BIND 9.x before 9.9.7-P2 and 9.10.x before 9.10.2-P3 allows remote attackers to cause a denial of service (REQUIRE assertion failure and daemon exit) via TKEY queries.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	juniper/junos, juniper/j2300, juniper/j2320, juniper/j2350, juniper/j4300
Risk Score	7.5 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2015-5477

CVE-2016-3081

CVE Title	CVE-2016-3081 | huawei/agile_controller-campus_firmware | Unknown Type
CVE Description	Apache Struts 2.3.19 to 2.3.20.2, 2.3.21 to 2.3.24.1, and 2.3.25 to 2.3.28, when Dynamic Method Invocation is enabled, allow remote attackers to execute arbitrary code via method: prefix, related to chained expressions.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	huawei/agile_controller-campus_firmware, huawei/agile_controller-campus, huawei/anyoffice, huawei/logcenter, huawei/firehunter6000_firmware
Risk Score	8.1 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2016-3081

CVE-2023-22894

CVE Title	CVE-2023-22894 | strapi/strapi | Unknown Type
CVE Description	Strapi through 4.5.5 allows attackers (with access to the admin panel) to discover sensitive user details by exploiting the query filter. The attacker can filter users by columns that contain sensitive information and infer a value from API responses. If the attacker has super admin access, then this can be exploited to discover the password hash and password reset token of all users. If the attacker has admin panel...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	strapi/strapi
Risk Score	4.9 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2023-22894

CVE-2021-3199

CVE Title	CVE-2021-3199 | onlyoffice/document_server | Remote Code Execution
CVE Description	Directory traversal with remote code execution can occur in /upload in ONLYOFFICE Document Server before 5.6.3, when JWT is used, via a /.. sequence in an image upload parameter.
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	onlyoffice/document_server
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2021-3199

CVE-2015-3306

CVE Title	CVE-2015-3306 | fedoraproject/fedora | Unknown Type
CVE Description	The mod_copy module in ProFTPD 1.3.5 allows remote attackers to read and write to arbitrary files via the site cpfr and site cpto commands.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	fedoraproject/fedora, debian/debian_linux, opensuse/tumbleweed, suse/linux_enterprise_server, proftpd/proftpd
Risk Score	10.0 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2015-3306

🧪 Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-105123

CVE Title	CVE-2026-105123 | 待核實 | Remote Code Execution
CVE Description	W (vincent-peugnet/wcms) through 3.18.0 contains a remote code execution vulnerability that allows authenticated editors to write arbitrary files by abusing the unvalidated path in POST /api/v0/media/upload/[*:path]. Attackers can upload .php files executed by the web server, use encoded ../ sequences to write outside the media directory, and delete arbitrary files via DELETE /api/v0/media/[*:path].
Affected Products	待核實
Risk Score	8.8 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-105123

CVE-2026-105124

CVE Title	CVE-2026-105124 | 待核實 | XSS
CVE Description	W (vincent-peugnet/wcms) through 3.18.0 contains a stored cross-site scripting vulnerability that allows unauthenticated attackers to inject scripts via the login user field and visitor comment website field. Attackers can submit failed logins rendered unescaped in the adminlog.php log viewer, or comment URLs echoed into href attributes in editrightbar.php, executing script with administrator or editor privileges.
Affected Products	待核實
Risk Score	6.1 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-105124

CVE-2026-105125

CVE Title	CVE-2026-105125 | 待核實 | Unknown Type
CVE Description	LaraDashboard before 1.4.8 contains a path traversal vulnerability that allows unauthenticated attackers to read JSON files by manipulating the {lang} route segment. On Windows hosts, attackers can send URL-encoded backslash sequences like ..%5C to escape resources/lang and read composer.json or other application JSON files.
Affected Products	待核實
Risk Score	3.7 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-105125

CVE-2026-105126

CVE Title	CVE-2026-105126 | 待核實 | Unknown Type
CVE Description	LaraDashboard before 1.4.8 contains an improper privilege management vulnerability that allows authenticated Admin users to escalate to Superadmin by editing or renaming roles. Attackers with role.edit can rename their role to Superadmin or grant user.login_as permissions to take over accounts and reach core upgrade and module installation functions for code execution.
Affected Products	待核實
Risk Score	7.2 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-105126

Report B: Threat Intelligence News (last 7 days)

Headline: Post-quantum authentication: Why organizations should start testing certificate ecosystems now

Source	Microsoft Security Blog
Published	Thu, 08 Oct 2026 20:44:28 +0000
Key Takeaway	Prepare for post-quantum authentication by testing certificate ecosystems now. Learn how Microsoft's PQC TLS Pilot Program helps advance future readiness. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/10/08/post-quantum-authentication-why-organizations-should-start-testing-certificate-ecosystems-now/

Headline: 3 lessons from frontier AI vulnerability research

Source	Microsoft Security Blog
Published	Wed, 07 Oct 2026 16:00:00 +0000
Key Takeaway	Read how How Microsoft Security's FORGE Lab is scaling vulnerability research from Windows to the Linux kernel. The post 3 lessons from frontier AI vulnerability research appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/10/07/3-lessons-from-frontier-ai-vulnerability-research/

Headline: CISA, FBI, NSA and International Partners Warn of China-based Cybersecurity Company Enabling Threat Actors to Target Multiple Critical Infr...

Source	CISA News
Published	Thu, 08 Oct 26 12:00:00 +0000
Key Takeaway	CISA, FBI, NSA and International Partners Warn of China-based Cybersecurity Company Enabling Threat Actors to Target Multiple Critical Infrastructure Sectors Worldwide Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/worldwide
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-fbi-nsa-and-international-partners-warn-china-based-cybersecurity-company-enabling-threat

Headline: CISA Launches Cybersecurity Awareness Month: Securing the Next 250

Source	CISA News
Published	Thu, 01 Oct 26 12:00:00 +0000
Key Takeaway	CISA Launches Cybersecurity Awareness Month: Securing the Next 250 Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-launches-cybersecurity-awareness-month-securing-next-250

Headline: Making sure the checks get printed

Source	Cisco Talos Blog
Published	Thu, 08 Oct 2026 18:00:29 GMT
Key Takeaway	Pierre's debut newsletter explores the messy, real-world side of risk management and how to keep vital systems running when a perfect patch isn't an option. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/making-sure-the-checks-get-printed/

Headline: UAT-11985: AI-assisted event lures delivering real-time Google AitM phishing

Source	Cisco Talos Blog
Published	Thu, 08 Oct 2026 10:01:06 GMT
Key Takeaway	Cisco Talos identified an APT spear-phishing campaign against individuals affiliated with Taiwan research organizations. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	待核實/taiwan
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/uat-11985/

Headline: The Third-Party Agent Problem: Why Security Built for AI You Chose Misses the Agents You Didn't

Source	The Hacker News
Published	Sat, 10 Oct 2026 16:30:00 +0530
Key Takeaway	In environments studied for the 2026 State of Agent Security Report, roughly 1,280 third-party products now embed AI. About 282 of them sit behind single sign-on. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/10/the-third-party-agent-problem-why.html

Headline: Anthropic Cuts Live Internet Access for Internal AI Tests After Claude Exploits Injection Flaws

Source	The Hacker News
Published	Sat, 10 Oct 2026 14:48:45 +0530
Key Takeaway	Anthropic on Friday said it's cutting off live internet access for all its internal evaluations following the discovery of new incidents in which its artificial intelligence (AI) models exhibited misaligned behavior and targeted real websites. The AI company said it identified four broad categories Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/10/anthropic-cuts-live-internet-access-for.html

Headline: Insider Cyber Extortion Plot Against Industrial Firm Lands Engineer in Prison

Source	SecurityWeek
Published	Sat, 10 Oct 2026 11:00:00 +0000
Key Takeaway	The former core infrastructure engineer deleted admin accounts, reset hundreds of passwords, and demanded 20 bitcoin to spare the company’s servers. The post Insider Cyber Extortion Plot Against Industrial Firm Lands Engineer in Prison appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	industrial/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/insider-cyber-extortion-plot-against-industrial-firm-lands-engineer-in-prison/

Headline: OpenAI Fires 3 Safety Researchers in Dispute Over AI Risks

Source	SecurityWeek
Published	Fri, 09 Oct 2026 21:07:46 +0000
Key Takeaway	The ChatGPT maker said the researchers "violated clear policies on handling sensitive information." The post OpenAI Fires 3 Safety Researchers in Dispute Over AI Risks appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/openai-fires-3-safety-researchers-in-dispute-over-ai-risks/

Headline: Cyber exec arrested in case allegedly tied to ShinyHunters hackers

Source	BleepingComputer
Published	Sat, 10 Oct 2026 11:07:54 -0400
Key Takeaway	Canadian cybersecurity executive Edward Dubrovsky has been arrested in Pennsylvania in connection with alleged extortion activity that multiple reports have linked to the FBI's ongoing crackdown on the ShinyHunters hacking group. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/cyber-exec-arrested-in-case-allegedly-tied-to-shinyhunters-hackers/

Headline: ARTEX AI, Claude agents used in cyberattacks on South Korean banks

Source	BleepingComputer
Published	Sat, 10 Oct 2026 10:16:17 -0400
Key Takeaway	The cyberattacks that shook the South Korean financial sector earlier this month were launched by a Chinese hacker using the ARTEX AI penetration testing suite and Claude agents. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	financial/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/hacker-used-artex-ai-and-claude-agents-to-target-south-korean-banks/

📚 Sources (official/authoritative first)

https://www.cisa.gov/known-exploited-vulnerabilities-catalog

https://nvd.nist.gov/

https://www.cve.org/

https://attack.mitre.org/

https://www.microsoft.com/en-us/security/blog/

https://www.cisa.gov/news-events/cybersecurity-advisories

https://www.mandiant.com/resources

https://blog.talosintelligence.com/